



Student Name: -Kumbhar Dilip

College Name: - Indus University

Internship: - Cyber Security Internship

Organization: - DG Intern Hub

Week 5 Assignment: - VAPT Tools – Practical Learning

SID: - dg/September/cyber/264

Mail: - dilipkumbhar.dginternshub@gmail.com

Task 5: - Theory + Practical



Sr. No.	Topic / Subtopics
1	Introduction to VAPT ➤ What is VAPT? ➤ Vulnerability Assessment ➤ Penetration Testing ➤ Difference Between VA and PT ➤ Importance of Authorized Testing
2	Lab Environment ➤ Operating System – Kali Linux ➤ Target – testphp.vulnweb.com ➤ Tools Used – Nmap, Nikto, Burp Suite ➤ Authorized Testing Environment
3	Nmap – Network Scanning ➤ Introduction to Nmap ➤ -sS, -sV, and -A Scans ➤ Results and Analysis ➤ Screenshots
4	Nikto – Web Server Scanning ➤ Introduction to Nikto ➤ Command Used ➤ Findings ➤ Analysis ➤ Screenshots
5	Burp Suite – Web Security Testing ➤ Introduction to Burp Suite ➤ Proxy ➤ HTTP Requests and Responses ➤ Headers ➤ Cookies ➤ Screenshots
6	VAPT Findings ➤ Finding ID ➤ Finding Description ➤ Tool Used ➤ Risk Level ➤ Evidence
7	Recommendations
8	Learning / Challenges
9	Conclusion



Introduction to VAPT

1. What is VAPT?

VAPT stands for **Vulnerability Assessment and Penetration Testing**.

- It is a security testing process used to find weaknesses in a system, network, application, or website.
 - VAPT helps organizations understand **where their security is weak** and how those weaknesses could be misused.
 - The main goal is to **find security problems before real attackers find them**.
-

2. Vulnerability Assessment (VA)

Vulnerability Assessment is the process of identifying and analyzing security weaknesses in a system.

Main points:

- Identifies possible vulnerabilities.
 - Uses security scanners and other testing tools.
 - Checks systems, applications, networks, and devices.
 - Usually produces a report containing:
 - Vulnerability details
 - Severity level
 - Affected systems
 - Recommended fixes
 - It mainly answers: **"What security weaknesses exist?"**
-

3. Penetration Testing (PT)

Penetration Testing is an authorized security test where security professionals try to exploit vulnerabilities in a controlled environment.

In simple words:

It is like **a security professional checking whether a weak door can actually be opened**.

Main points:

- Attempts to safely exploit identified weaknesses.
- Shows the real impact of a vulnerability.
- Helps determine how far an attacker could go.
- Can reveal weaknesses that automated scanners may miss.



- Requires careful planning and defined testing limits.
- It mainly answers: **"Can this weakness actually be exploited, and what could happen?"**

4. Difference Between Vulnerability Assessment and Penetration Testing

Point	Vulnerability Assessment (VA)	Penetration Testing (PT)
Meaning	Finds and identifies vulnerabilities.	Attempts to exploit vulnerabilities.
Main Goal	Discover security weaknesses.	Check whether weaknesses can actually be exploited.
Approach	Mainly identifies and analyzes.	Actively tests and exploits in a controlled way.
Risk	Generally lower risk because it mainly identifies issues.	Higher risk because exploitation is involved.
Tools	Mostly automated scanners and security tools.	Automated tools plus manual testing techniques.
Result	List of vulnerabilities with severity and recommendations.	Evidence of exploitation and the possible impact.
Question answered	"What vulnerabilities are present?"	"Can the vulnerability be exploited?"
Frequency	Can be performed regularly.	Usually performed based on specific requirements or schedules.
Example	Finding that a server has an outdated software version.	Safely testing whether that outdated software can be used to gain unauthorized access.

5. Importance of Authorized Testing

Authorized testing is very important because security testing involves accessing and sometimes attempting to exploit systems.

Why authorization is important:

- **Legal protection:** Testing without permission can be illegal, even if your intention is to improve security.
- **Avoids damage:** Authorized testers know what systems they are allowed to test and what actions are restricted.
- **Defines the scope:** The organization can specify the IP addresses, applications, domains, and systems that can be tested.
- **Protects sensitive data:** Testing can sometimes expose confidential information, so proper controls are required.
- **Prevents unnecessary disruption:** Testers can avoid actions that might crash systems or affect business operations.



- **Builds trust:** Written authorization makes the testing process clear to both the organization and the security team.
- **Provides accountability:** Everyone knows who is performing the test, what will be tested, and when it will happen.

1. Prepare Kali Linux

Open Terminal:

- `sudo apt update`

Install the required tools:

- `sudo apt install nmap nikto burpsuite -y`

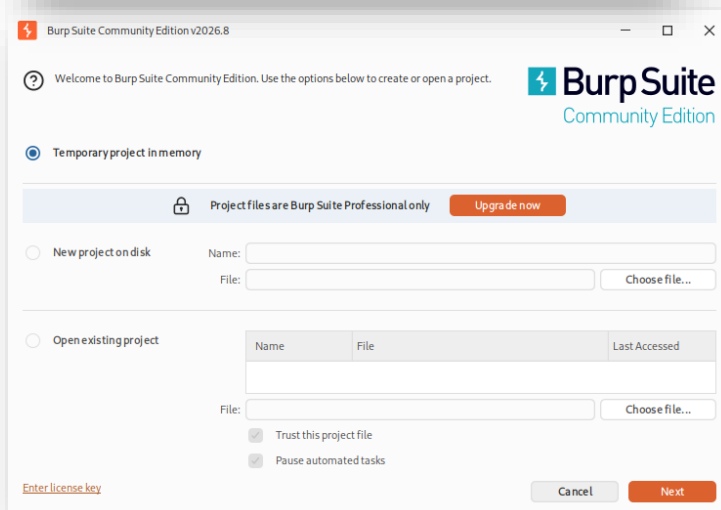
Check installation:

- `nmap --version`
- `nikto -Version`

For Burp Suite:

- `burp suite`

```
(kali@kali)-[~]
└─$ nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.8 openssl-3.6.4 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.7 nmap-libdnet-1.18.0 ipv6
Compiled without:
Available nsock engines: epoll poll select
```



```
(kali@kali)-[~]
└─$ nikto
- Nikto v2.6.1

+ ERROR: No host (-host) specified

Options:
  -Add-header      Add HTTP headers (can be used multiple times, one per header
pair)
  -ask+           Whether to ask about submitting updates
                  yes   Ask about each (default)
                  no    Don't ask, don't send
                  auto  Don't ask, just send
  -check6         Check if IPv6 is working (connects to ipv6.google.com or valu
e set in nikto.conf)
  -Cgidirs+       Scan these CGI dirs: "none", "all", or values like "/cgi/ /cg
i-a/"
  -config+        Use this config file
  -Display+       Turn on/off display output
```



2. Nmap – Network Scanning

Target:

- testaspnet.vulnweb.com

Scan 1 – SYN Scan

```
(kali㉿kali)-[~]
$ sudo nmap -sS -p- 44.238.29.244 -oX week5_scan_network
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 08:49 -0400
Nmap scan report for ec2-44-238-29-244.us-west-2.compute.amazonaws.com (44.238.29.244)
Host is up (0.00038s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 284.30 seconds
```

Scan 1 – Nmap Aggressive Scan

Run:

- nmap -A testaspnet.vulnweb.com

-A enables several detection features, including:

- OS detection
- Service/version detection
- Default NSE scripts
- Traceroute

```
(kali㉿kali)-[~]
$ sudo nmap -sA -p- 44.238.29.244 -oX week5_scan_network2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 08:50 -0400
Nmap scan report for 44.238.29.244
Host is up (0.00075s latency).
All 65535 scanned ports on 44.238.29.244 are in ignored states.
Not shown: 65535 unfiltered tcp ports (reset)
Nmap done: 1 IP address (1 host up) scanned in 36.62 seconds
```

2. Nikto – Web Vulnerability Scan

Start Nikto:

- nikto -h http://testaspnet.vulnweb.com

Nikto checks the web server for things such as:

- Interesting files/directories
- Server configuration issues
- Missing security headers
- Known web-server issues
- Potentially exposed information



```
(kali@kali) ~/Desktop/week5
$ nikto -h http://testaspnet.vulnweb.com -output nikto-scan.txt
- Nikto v2.6.1

+ Target IP: 44.238.29.244
+ Target Hostname: testaspnet.vulnweb.com
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-10-05 09:13:14 (GMT-4)

+ Server: Microsoft-IIS/8.5
+ [000287] /: Retrieved x-aspnet-version header: 2.0.50727.
+ [000287] /: Retrieved x-powered-by header: ASP.NET.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ [999985] OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ [600376] Microsoft-IIS/8.5 may be outdated (current is at least 10.0; IIS 6.0 support is available until 2014).
+ [750537] /: Default IIS server content. See: https://www.iis.net/
+ [999979] /aspnet_client: RFC-1918 IP address found in the 'location' header. The IP is '10.0.0.14'. See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [999988] /aspnet_client: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is '10.0.0.14'. See: https://nvd.nist.gov/vuln/detail/CVE-2000-0649
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://
```

3. Burp Suite

Now perform the third part.

Start Burp:

- burpsuite

Choose:

Temporary Project → Next → Use Burp Defaults → Start Burp

Configure Burp Suite Browser

- I opened Burp Suite and used its built-in browser, so I did not need to configure Firefox manually.

In Burp Suite, I checked:

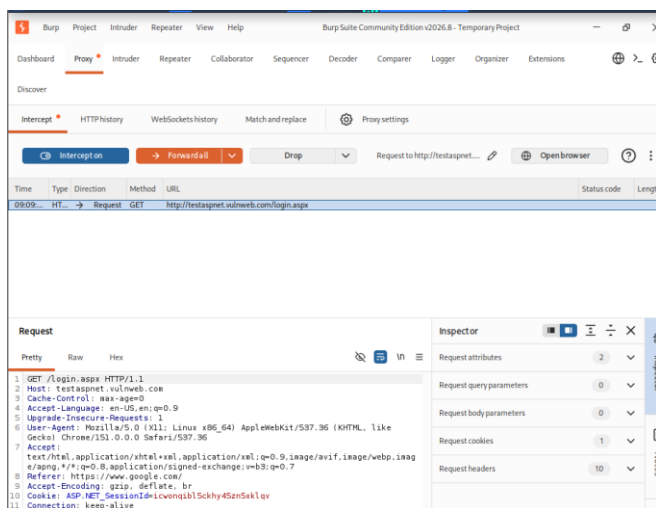
- Proxy → Proxy settings

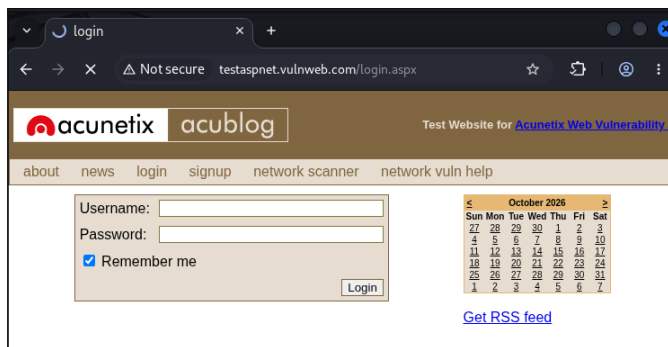
The proxy listener was running on:

- 127.0.0.1:8080

I then opened Burp's built-in browser and visited:

<http://testaspnet.vulnweb.com>





I looked at the following parts of the request:

- Method: Shows what action the browser is requesting, such as GET or POST.
- Path/URL: Shows which page or resource is being requested.
- Host: Shows the website being contacted.
- Headers: Provide extra information about the browser and request.
- Cookies: Can contain information used to maintain a session.

Capture HTTP Requests

I went to:

- Proxy → Intercept
- Turned Intercept ON.

I visited different pages on the authorized training website. Burp Suite captured the HTTP requests sent by the browser.



Find at Least 3 Issues

This is the most important part of your mini-project.

You should combine information from:

- **Nmap + Nikto + Burp Suite**

For example, your findings could be structured as:

Finding 1 – Exposed Web Service

- ⇒ **Evidence:** Nmap
- ⇒ 80/tcp open http

Explanation:

- Nmap identified an HTTP service running on the target. This confirms that a web service is publicly reachable.

Risk:

- An exposed web service increases the attack surface and should be properly secured and maintained.

Finding 2 – Web Server Security Configuration

- ⇒ **Evidence:** Nikto
- ⇒ Use an **actual finding from your Nikto output**.

Explanation:

- Nikto identified a web-server configuration/security observation. This indicates that the server configuration could be improved.

Recommendation:

- Review the web-server configuration and enable appropriate security controls.

Finding 3 – HTTP Request Information

- ⇒ **Evidence:** Burp Suite

Explanation:

- Burp Suite allowed the HTTP request and headers to be inspected. This demonstrates how information is transmitted between the browser and web server.
- Then explain the security implication based on what you actually observed.



Recommendations

1. Remove unnecessary services.
 2. Keep software updated.
 3. Configure web-server security properly.
 4. Use HTTPS for web communication.
 5. Apply appropriate HTTP security headers.
 6. Monitor web-server logs.
 7. Follow least-privilege principles.
-

Learning / Challenges

Write what you learned:

- Basic network scanning
 - Service enumeration
 - Web vulnerability scanning
 - HTTP request analysis
 - Headers and cookies
 - Security findings
 - Report preparation
-

Conclusion

This practical helped me understand the basic workflow of Vulnerability Assessment and Penetration Testing. I used Nmap to identify available services, Nikto to inspect the web server for security-related findings, and Burp Suite to understand HTTP requests and responses. I learned that scanning results should be analyzed carefully instead of simply copying tool output. The practical also improved my understanding of attack surface, web security, and security recommendations. All testing was performed only against the authorized training environment.